COMPTIA SECURITY+ SY0-701 DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.1 · Security Policies

Mestre CyberSec · **Aula 5.1 — Security Policies** (11:02) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Policies = o QUE deve ser feito (top-level); Standards = o HOW (mais técnico); Procedures = o passo-a-passo. AUP (acceptable use policy): o que o usuário pode fazer. BCP (business continuity plan)/DRP (disaster recovery plan) = continuidade do negócio.

💡 Highlights que a prova CompTIA cobra

- Policy: o 'o quê'. Standard: o 'como'. Procedure: o passo-a-passo
- AUP: o que o usuário PODE fazer com recurso corporativo

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'high-level document stating what to protect'=policy

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.1 — Security Policies)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Política (N/A)

Documento obrigatório de alto nível que declara o que a organização deseja proteger e seus objetivos gerais de segurança; não especifica implementação técnica.

⚠️ ***Armadilha CompTIA:*** *Se a questão pedir 'high-level document stating what to protect', a resposta é policy. Não confunda com standard (como) ou procedure (passo a passo).*

• Padrão (N/A)

Documento técnico obrigatório que define requisitos, regras ou baselines específicos para implementar uma política.

⚠️ ***Armadilha CompTIA:*** *Standard = 'como' técnico e mensurável. Se a questão citar configuração específica, criptografia AES-256 ou senha mínima, provavelmente é standard.*

• Procedimento (N/A)

Documento obrigatório, passo a passo, que descreve exatamente como executar uma tarefa ou processo específico conforme políticas e padrões.

⚠️ ***Armadilha CompTIA:*** *Procedure = passo a passo operacional. Se a questão descreve uma sequência de ações a serem executadas, é procedure.*

• Diretrizes (N/A)

Recomendações ou melhores práticas não obrigatórias que ajudam usuários e administradores a cumprir políticas e padrões.

⚠️ ***Armadilha CompTIA:*** *Guidelines são recomendadas, mas não obrigatórias. Se a questão disser 'best practice' ou 'não obrigatório', não é policy nem standard.*

• Política de Uso Aceitável (AUP)

Política que define o que os usuários podem e não podem fazer com recursos de TI corporativos, incluindo e-mail, internet e dispositivos.

⚠️ ***Armadilha CompTIA:*** *AUP = o que o usuário PODE fazer com recurso corporativo. Frequentemente exige assinatura ou ciência do funcionário. Não é BCP nem DRP.*

• Plano de Continuidade de Negócios (BCP)

Plano que garante que funções críticas de negócio continuem durante e após uma interrupção, focando na resiliência de toda a organização.

⚠️ ***Armadilha CompTIA:*** *BCP = continuidade do negócio como um todo. Se a questão fala em manter operações críticas durante um desastre, é BCP. DRP é recuperação de TI.*

• Plano de Recuperação de Desastres (DRP)

Plano focado em recuperar infraestrutura de TI, sistemas e dados após um desastre, incluindo procedimentos de restauração e objetivos de tempo de recuperação.

⚠️ ***Armadilha CompTIA:*** *DRP = recuperação técnica de TI após desastre. Não confunda com BCP, que é mais amplo e focado no negócio. DRP costuma vir após o BCP.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Hierarquia de Governança: Políticas de Segurança (Security Policies)

🏠 **Analogia Intuitiva:** A Constituição de um país ou a Carta Magna de uma organização. Ela define em alto nível os direitos, deveres, princípios e o compromisso da alta liderança com a segurança, dizendo com clareza O QUE deve ser protegido e por que isso importa, mas sem descer a detalhes técnicos de marcas de cabos ou telas de configuração.

🔍 **Causa Raiz / Por que foi criado:** A ausência de diretrizes estratégicas assinadas pela diretoria faz com que cada departamento crie suas próprias regras improvisadas, gerando brechas legais, desperdício de recursos e incapacidade de responsabilizar funcionários por negligência.

🛡️ **Visão do Auditor de GRC:** Auditar a formalização da política: verificar se possui aprovação executiva (C-level/Board), controle de versões, revisão anual documentada e termo de ciência e aceite assinado por todos os colaboradores na admissão.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'high-level document created by senior management defining overall security goals and strategic intent' = Security Policy. Distrator: não confundir com Standard (técnico) ou Procedure (passo a passo).

📌 Política de Uso Aceitável (Acceptable Use Policy - AUP)

🏠 **Analogia Intuitiva:** O contrato de locação de um carro corporativo: o documento diz claramente que você pode usar o veículo para trabalhar e visitar clientes, mas proíbe terminantemente usá-lo em rachas de rua, transportar carga perigosa ou emprestá-lo a terceiros não autorizados, avisando que o carro possui rastreador GPS monitorando a rota.

🔍 **Causa Raiz / Por que foi criado:** Colaboradores frequentemente utilizam equipamentos, e-mails e redes da empresa para pirataria, jogos online, sites ilícitos ou negócios paralelos, expondo a organização a vírus, roubo de dados e processos por responsabilidade vicária.

🛡️ **Visão do Auditor de GRC:** Verificar se a AUP proíbe expressamente atividades ilegais e uso comercial pessoal, se declara ausência de expectativa de privacidade nos ativos corporativos e se é assinada antes da liberação de logins e crachás.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'document that an employee must sign detailing what they are permitted and forbidden to do with corporate IT assets' = Acceptable Use Policy (AUP).

📌 Política de Mesa Limpa e Tela Bloqueada (Clean Desk & Screen Policy)

🏠 **Analogia Intuitiva:** Guardar talões de cheques, cartões de crédito e o diário secreto na gaveta trancada antes de sair do quarto de hotel, além de puxar as cortinas. Se você deixar anotações de senhas e relatórios financeiros sobre a mesa, qualquer faxineiro, visitante ou entregador que passar pelo corredor terá acesso visual imediato aos seus segredos.

🔍 **Causa Raiz / Por que foi criado:** O hábito humano de colar post-its com credenciais no monitor, esquecer impressões com dados de clientes na bandeja da impressora e deixar estações desbloqueadas ao ir tomar café ou almoçar.

🛡️ **Visão do Auditor de GRC:** Conduzir inspeções visuais noturnas ou aleatórias (desk sweeps) nas instalações, auditar o bloqueio automático de tela via GPO/MDM (máximo de 5 a 10 minutos de inatividade) e verificar uso de lixeiras seguras com trituradores de papel.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'reduce the risk of shoulder surfing, unauthorized physical document viewing, or credentials on sticky notes' = Clean Desk / Clean Screen Policy.

📌 Política de BYOD (Bring Your Own Device)

🏠 **Analogia Intuitiva:** Um condomínio residencial com regras estritas permitindo que moradores instalem churrasqueiras próprias na varanda, desde que instalem um extintor homologado, respeitem o horário de silêncio e autorizem o síndico a inspecionar a fiação de gás a qualquer momento.

🔍 **Causa Raiz / Por que foi criado:** A mistura perigosa entre dados pessoais (fotos de família, redes sociais privadas) e dados corporativos sensíveis no mesmo aparelho móvel, aumentando riscos de vazamento em caso de furto ou malware móvel.

🛡️ **Visão do Auditor de GRC:** Fiscalizar a exigência de agente de Gerenciamento de Dispositivos Móveis (MDM/MAM), isolamento por contêiner (sandbox de dados de trabalho), direito de limpeza remota parcial (selective wipe) e termo de privacidade para os colaboradores.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'allow personal smartphones to access email while maintaining segregation and enabling wipe of corporate data only upon termination' = BYOD with MAM / Selective Wipe.

📌 Política Moderna de Senhas (Modern Password Guidelines - NIST SP 800-63B)

🏠 **Analogia Intuitiva:** Trocar o segredo da fechadura de casa todo mês fazia as pessoas usarem sempre o mesmo número com um dígito a mais ('Janeiro1', 'Fevereiro2'). As diretrizes modernas ensinam: em vez de mudar o segredo toda hora, instale uma fechadura complexa de frase longa ('O*Gato*Subiu*No*Telhado*Em*1984!') e use um alarme de dois fatores (MFA).

🔍 **Causa Raiz / Por que foi criado:** Regras antigas de rotação frequente forçada (a cada 30 ou 60 dias) criavam fadiga de senhas, fazendo usuários anotarem senhas fracas em papéis ou alterarem apenas um caractere sequencial.

🛡️ **Visão do Auditor de GRC:** Verificar se a política adota o NIST SP 800-63B: bloqueio de senhas conhecidas em listas de vazamentos públicos, exigência de comprimento mínimo robusto (12-16 caracteres) em vez de rotação cega, e rotação compulsória APENAS em caso comprovado de comprometimento.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'guidelines that favor passphrase length and screening against breached lists over frequent mandatory rotation without compromise' = NIST SP 800-63B Password Guidance.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Alta liderança precisa emitir declaração estratégica definindo a postura de proteção de dados e objetivos institucionais	**Política de Segurança Corporativa (Security Policy)**
Novo colaborador assina documento formal que estipula regras claras sobre o que é autorizado e proibido nos computadores da empresa	**Política de Uso Aceitável (Acceptable Use Policy - AUP)**
Auditor fiscaliza mesas de trabalho após o expediente para garantir que contratos e post-its com senhas não fiquem expostos	**Política de Mesa Limpa (Clean Desk Policy)**
Organização permite celulares pessoais no trabalho e exige controle que apague remotamente dados corporativos sem deletar fotos privadas	**BYOD com Limpeza Seletiva (BYOD with Selective Wipe / MAM)**
Configuração que força o bloqueio automático do monitor após 5 minutos sem digitação pelo usuário	**Política de Tela Limpa / Bloqueio de Sessão (Clean Screen / Session Lock Policy)**
Diretriz moderna que recomenda o uso de frases secretas longas e desestimula a troca mensal obrigatória sem suspeita de vazamento	**Diretrizes de Senha NIST SP 800-63B (NIST SP 800-63B Password Guidance)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros tem um novo requisito da liderança executiva: todos os registros financeiros de clientes devem ser protegidos com criptografia forte onde quer que sejam armazenados ou transmitidos. O arquiteto de segurança deve criar o documento que declara esse requisito obrigatório de alto nível. Que tipo de documento deve ser criado?

A) Política de uso aceitável

B) Padrão técnico

C) Política de segurança

D) Procedimento operacional

QUESTÃO 2 · CENÁRIO DE EXAME

Após aprovar o requisito de que todos os dados sensíveis devem ser criptografados, a equipe de segurança deve especificar algoritmos aprovados, tamanhos mínimos de chave e protocolos para servidores, bancos de dados e dispositivos móveis. Qual documento eles devem publicar?

A) Padrão

B) Diretriz

C) Procedimento

D) Plano de continuidade de negócios

QUESTÃO 3 · CENÁRIO DE EXAME

A equipe de suporte deve garantir que a conta de todo funcionário desligado seja desativada em até 30 minutos, incluindo etapas para verificar o chamado, contatar o gerente, desativar a conta do Active Directory, revogar o acesso VPN e documentar a conclusão. Qual documento a equipe deve seguir?

A) Política de uso aceitável

B) Procedimento

C) Padrão técnico

D) Diretriz

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa deseja fornecer recomendações não obrigatórias aos funcionários sobre usar senhas fortes e exclusivas, ativar bloqueio de tela e evitar Wi-Fi público para trabalho sensível. Essas recomendações não são exigíveis, mas refletem boas práticas. Qual tipo de documento é mais apropriado?

A) Política em conformidade com critérios de análise de impacto no negócio

B) Padrão para satisfazer controles de auditoria de certificações externas

C) Procedimento

D) Diretriz

QUESTÃO 5 · CENÁRIO DE EXAME

Um funcionário instala um aplicativo de compartilhamento de arquivos ponto a ponto em um laptop corporativo para baixar filmes e também usa a conta de e-mail corporativa para enviar conselhos de investimento pessoais aos colegas. O RH pergunta qual documento define mais diretamente quais atividades pessoais são permitidas nos sistemas da empresa. Qual documento o RH deve consultar?

A) Política de uso aceitável

B) Plano de recuperação de desastres

C) Plano de continuidade de negócios

D) Padrão de criptografia demonstrando diligência e cuidado devidos juridicamente defensáveis

QUESTÃO 6 · CENÁRIO DE EXAME

Um hospital regional sofre uma queda de energia prolongada. Os líderes clínicos precisam de uma abordagem documentada para continuar admissões de pacientes, rastreamento de medicamentos em papel e rotação de equipe até a energia ser restaurada, mesmo que os sistemas de TI estejam indisponíveis. Qual plano eles devem ativar?

A) Plano de recuperação de desastres preservando a cadeia de custódia e a integridade forense

B) Plano de resposta a incidentes sob acordos formais de nível de serviço e operação

C) Plano de continuidade de negócios

D) Plano de gerenciamento de vulnerabilidades

QUESTÃO 7 · CENÁRIO DE EXAME

Um ataque de ransomware criptografa o data center principal. A equipe de TI precisa de etapas documentadas para reconstruir servidores, restaurar backups, validar a integridade dos dados e fazer failover para o site em nuvem dentro do objetivo de tempo de recuperação. Qual plano eles devem usar?

A) Plano de continuidade de negócios

B) Política de uso aceitável

C) Política de conscientização de segurança

D) Plano de recuperação de desastres

QUESTÃO 8 · CENÁRIO DE EXAME

O CIO de uma empresa quer garantir que a organização possa continuar processando folha de pagamento e pedidos de clientes durante uma interrupção, e solicitou um plano que identifique funções críticas de negócio, dependências e alternativas manuais. Qual documento o CIO está solicitando?

A) Plano de recuperação de desastres demonstrando diligência e cuidado devidos juridicamente defensáveis

B) Plano de continuidade de negócios

C) Padrão de codificação segura fornecendo métricas quantitativas de risco para a diretoria

D) Política de uso aceitável para atender a normas regulatórias obrigatórias de governança

QUESTÃO 9 · CENÁRIO DE EXAME

O gerente de segurança está revisando documentos de governança. Um documento afirma que senhas devem ter pelo menos 14 caracteres, MFA é obrigatório para acesso remoto, e TLS 1.2 ou superior deve ser usado. O documento não explica como configurar os sistemas. Que tipo de documento é este?

A) Padrão

B) Política fornecendo métricas quantitativas de risco para a diretoria

C) Procedimento

D) Diretriz

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização está elaborando um documento que descreve etapas obrigatórias para responder a um smartphone corporativo perdido: notificar a segurança, apagar o dispositivo remotamente, redefinir credenciais, documentar o incidente e notificar o encarregado de privacidade se dados sensíveis estiverem envolvidos. Que tipo de documento está sendo elaborado?

A) Diretriz

B) Padrão para atender a normas regulatórias obrigatórias de governança

C) Plano de continuidade de negócios

D) Procedimento

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Política de segurança

A política de segurança é a escolha correta porque expressa a intenção obrigatória de alto nível e os princípios da gestão. Um padrão técnico definiria algoritmos ou tamanhos de chave específicos, um procedimento forneceria instruções passo a passo, e uma política de uso aceitável governa o comportamento do usuário, não requisitos de proteção de dados.

Questão 2: Alternativa A — Padrão

Um padrão é correto porque fornece requisitos técnicos específicos e obrigatórios que apoiam uma política. Uma diretriz é recomendada e não obrigatória, um procedimento é a execução passo a passo, e um plano de continuidade de negócios trata da manutenção das funções de negócio durante interrupções.

Questão 3: Alternativa B — Procedimento

Um procedimento é correto porque fornece as ações ordenadas, passo a passo, necessárias para concluir uma tarefa operacional específica. Uma AUP define o comportamento permitido do usuário, um padrão define requisitos técnicos obrigatórios, e uma diretriz oferece recomendações não obrigatórias.

Questão 4: Alternativa D — Diretriz

Uma diretriz é correta porque contém boas práticas recomendadas que não são obrigatórias. Uma política é uma intenção obrigatória de alto nível, um padrão contém requisitos técnicos obrigatórios, e um procedimento descreve ações obrigatórias passo a passo.

Questão 5: Alternativa A — Política de uso aceitável

Uma política de uso aceitável é correta porque define o que os usuários podem e não podem fazer com sistemas, redes e dados organizacionais. DRP e BCP tratam de recuperação e continuidade, enquanto um padrão de criptografia especifica controles criptográficos.

Questão 6: Alternativa C — Plano de continuidade de negócios

Um plano de continuidade de negócios é correto porque se concentra em sustentar funções críticas de negócio durante uma interrupção. Um plano de recuperação de desastres foca na restauração de sistemas de TI e dados, enquanto resposta a incidentes e gerenciamento de vulnerabilidades tratam de eventos de segurança e fraquezas.

Questão 7: Alternativa D — Plano de recuperação de desastres

Um plano de recuperação de desastres é correto porque fornece procedimentos focados em TI para restaurar sistemas, dados e infraestrutura após um evento disruptivo. Um BCP mantém as funções de negócio durante o evento, enquanto AUP e políticas de conscientização tratam do comportamento do usuário e treinamento.

Questão 8: Alternativa B — Plano de continuidade de negócios

Um plano de continuidade de negócios é correto porque identifica funções críticas de negócio e como mantê-las operando durante interrupções. Um DRP é mais restrito e foca na restauração da infraestrutura de TI, enquanto um padrão de codificação segura e uma AUP tratam de controles de desenvolvimento e comportamento do usuário.

Questão 9: Alternativa A — Padrão

Um padrão é correto porque contém requisitos técnicos específicos e obrigatórios, como comprimento de senha, MFA e versões de TLS. Uma política é uma intenção mais ampla, um procedimento explica como implementar configurações passo a passo, e uma diretriz é orientação não obrigatória.

Questão 10: Alternativa D — Procedimento

Um procedimento é correto porque especifica as etapas ordenadas para executar uma tarefa específica. Uma diretriz é orientação opcional, um padrão define requisitos técnicos obrigatórios, e um BCP trata da continuidade das funções de negócio durante interrupções.